Ê. R. Viana, F. Í. G. da Silva, Rev. Bras. Crim. 2026
Edição Especial dos Anais do XXVIII Congresso Nacional de Criminalística

2026
ISSN 2237-9223

REVISTA BRASILEIRA DE CRIMINALÍSTICA

Edição Especial dos Anais do

LOCARD PDF: Módulo Integrado de Análise Forense de Documentos PDF para o Framework Audiovisual LOCARD

Ê. R. Viana[a,b], F. Í. G. da Silva[a]

[a]*niversidade Federal do Ceará (UFC), Fortaleza (CE), Brasil*
[b]*Perícia Forense do Estado do Ceará (PEFOCE), Fortaleza (CE), Brasil*
[*]*Endereço de e-mail para correspondência: eniocc@gmail.com*

Palavras-chave: forense digital; análise de PDF; LOCARD; YARA; assinatura digital.

1. INTRODUÇÃO

O *Portable Document Format* (PDF) consolidou-se como o padrão de facto para o intercâmbio de documentos em ambientes corporativos, governamentais e judiciais. Sua flexibilidade — que permite encapsular textos, imagens, formulários interativos, código JavaScript, arquivos embutidos e assinaturas criptográficas — também o transformou em um dos vetores mais explorados por agentes maliciosos para a distribuição de malware e para a perpetração de fraudes documentais [2,7]. Em paralelo, peritos criminais brasileiros vêm enfrentando volumes crescentes de evidências documentais cuja análise exige ferramentas específicas, frequentemente fragmentadas entre utilitários de linha de comando, scripts isolados e suítes comerciais de código fechado [1].

O projeto *LOCARD: An Audiovisual Framework for Forensic Application* surgiu para enfrentar o problema da fragmentação de ferramentas na esfera multimídia, oferecendo uma plataforma unificada para análise de áudio e vídeo nos moldes do modelo forense distribuído brasileiro. No entanto, investigações reais raramente se restringem a uma única classe de evidência: documentos PDF acompanham *prints* de tela, chats exportados, vídeos de circuito interno e laudos periciais. Para preencher essa lacuna, foi desenvolvido o submódulo aqui descrito, denominado LOCARD PDF.

Este resumo expandido apresenta a arquitetura, as capacidades forenses e os fundamentos de implementação do submódulo LOCARD PDF, totalmente integrado ao ecossistema do *framework* hospedeiro. O nome do projeto remete diretamente ao princípio de Edmond Locard — segundo o qual todo contato deixa um traço — princípio que possui formulação análoga aplicável ao mundo digital [9]. O módulo entrega ao perito uma bancada única para inspeção estrutural, análise heurística, validação criptográfica e correlação de indicadores em documentos PDF, padronizando o fluxo de trabalho e preservando a cadeia de custódia.

2. FUNDAMENTAÇÃO TEÓRICA E TRABALHOS CORRELATOS

A análise forense de documentos PDF apresenta desafios estruturais que diferem substancialmente daqueles encontrados em mídias audiovisuais. A especificação ISO 32000 [10] define o PDF como um conjunto não linear de objetos indexados por uma *Cross-Reference Table* (XRef), o que permite quatro classes de complicações típicas para o examinador:

- Estrutura não linear: objetos espalhados ao longo do arquivo, com referências cíclicas, *Object Streams* (/ObjStm) e atualizações incrementais que podem ocultar versões anteriores do documento [10].
- Cadeias de codificação: dados úteis frequentemente residem dentro de cadeias de filtros (*FlateDecode*, ASCIIHexDecode, LZWDecode), exigindo decodificação ativa antes de qualquer varredura semântica.
- Conteúdo dinâmico: JavaScript embutido, ações /OpenAction e /AA (*Additional Actions*)

permitem a execução automática de código no momento da abertura, sendo um vetor recorrente em campanhas de *phishing* e *exploits* [2,7].

- Fraudes de assinatura: documentos em conformidade com PAdES podem ser modificados após assinados por meio dos chamados *Shadow Attacks*, comprovadamente eficazes contra a maioria dos leitores de mercado [4,5].

Ferramentas como pdfid e pdf-parser [3] popularizaram a triagem estática de PDFs, mas operam em linha de comando, exigem múltiplas invocações encadeadas e não integram visualização, validação de assinaturas, análise de entropia ou *threat hunting* baseado em regras. Pesquisas posteriores aplicaram aprendizado de máquina à detecção de PDFs maliciosos [7,8], porém na rotina pericial a explicabilidade dos achados continua sendo requisito imprescindível para o relatório técnico [1].

O *Peritus Framework* [1] demonstrou que a centralização de ferramentas em um ambiente único, auditável e modular eleva a qualidade da prova pericial em modelos distribuídos como o brasileiro. O submódulo LOCARD PDF transporta esse paradigma para a esfera documental, suprindo a lacuna entre triagem automatizada e dissecação manual aprofundada.

3. ARQUITETURA DO MÓDULO LOCARD PDF

O LOCARD PDF foi desenvolvido em C++ moderno e organizado em três camadas, com fronteiras claras entre o motor analítico, as fontes de dados e a interface gráfica. A Fig. 1 sintetiza a estratificação proposta. As bibliotecas externas adotadas são todas de código aberto: QPDF [12] para o parsing preservativo da estrutura PDF, Poppler para renderização visual fiel, YARA [11] para pattern matching heurístico, OpenSSL para criptografia assimétrica e hash, e Dear ImGui para a construção do front-end gráfico em estilo docking.

3.1. Abstração de fontes de dados

A interface *IDataSource* permite que toda a análise seja executada sobre fontes heterogêneas: arquivos em disco (*FileDataSource*), regiões de memória volátil (*MemoryDataSource, ProcessMemoryDataSource*), setores brutos de disco (*RawDiskDataSource*) e até pacotes de rede (*UdpPacketDataSource*). Essa abstração é estratégica em cenários nos quais o PDF não está disponível como artefato isolado — por exemplo, *carving* em imagens de disco, captura ao vivo de processos suspeitos ou interceptação de tráfego —, situações comuns no fluxo de triagem descrito em modelos forenses contemporâneos [1].

3.2. Motor analítico (PdfAnalyzer)

O PdfAnalyzer é a peça central do submódulo. Ele percorre a hierarquia de objetos PDF a partir do trailer, monta uma representação navegável da árvore de dicionários, *arrays*, *streams* e primitivos, e expõe APIs para cálculo estatístico, varredura de regras, decodificação ASN.1 (assinaturas PKCS#7) e extração de indicadores de comprometimento. Módulos especializados como *YaraManager, IOCExtractor e PdfComparator* operam sobre essa representação compartilhada, evitando releituras redundantes do arquivo bruto.

3.3. Interface gráfica e ergonomia

A camada gráfica utiliza Dear ImGui com painéis dockáveis, atalhos de teclado e layouts predefinidos (*Clean, General Analysis, Forensics*, *Visual Tools*). O analista pode salvar perfis próprios e alternar contextos rapidamente. Uma barra de busca centralizada (estilo *Spotlight*, atalho Ctrl+Space) localiza qualquer painel pelo nome, reduzindo a sobrecarga cognitiva característica de suítes com dezenas de janelas.

4. CAPACIDADES FORENSES E IMPLEMENTAÇÃO

O submódulo concentra mais de cinquenta funcionalidades distribuídas em dez categorias temáticas. As subseções a seguir descrevem o conjunto consolidado.

4.1. Navegação estrutural e inspeção de objetos

O painel *Object Tree* reconstrói o documento como árvore hierárquica, enquanto o *XRef Inspector* expõe a tabela de referência cruzada com gerações e *offsets*, condição necessária para identificar objetos não mapeados. O *Object Stream Explorer* navega dentro de objetos /ObjStm típicos de PDFs comprimidos e o *Action Flow Graph* visualiza, em forma de grafo, a cadeia Abertura → Gatilho JS → URI executada — recurso decisivo para evidenciar *malware* multifase [2].

4.2. Análise de baixo nível, entropia e slack space

O *Hex Editor* integrado oferece patching, marcadores e busca de padrões, operando indistintamente sobre disco, memória ou rede graças à abstração *IDataSource*. O *Stream Viewer* exibe o conteúdo bruto e decodificado dos streams, e o *Stream Decoder* permite testar filtros isolados (*Flate, ASCIIHex, LZW*) sobre fragmentos suspeitos. O *Hash Calculator* gera MD5,

SHA-1 e SHA-256 do arquivo ou de blocos, viabilizando a integridade da evidência e a consulta cruzada em bases como VirusTotal.

A análise de Entropia de Shannon é apresentada em histograma e em mapa térmico bidimensional. Como reportado na literatura [6], zonas com entropia superior a 7,5 bits/byte indicam fortemente a presença de dados cifrados, comprimidos ou ofuscados. O *Slack Space Inspector* examina o espaço após o marcador %EOF e os hiatos entre objetos — regiões reconhecidamente exploradas para ocultar *payloads* fora da estrutura indexada do documento.

4.3. Metadados, proveniência e linha do tempo

O painel Metadata lê tanto o dicionário /Info legado quanto os metadados XMP em XML, e a Timeline agrega todas as datas encontradas — criação, modificação, carimbos em assinaturas digitais e revisões — em visão cronológica única. O verificador PDF/A Compliance sinaliza recursos dinâmicos proibidos pelo padrão ISO de arquivamento de longo prazo, alertando sobre documentos atípicos. A função Geolocation extrai coordenadas GPS dos cabeçalhos XMP e dos EXIF de imagens embutidas, recurso útil em investigações de vazamento documental.

4.4. Heurística, análise incremental e caça a ameaças

Um avaliador heurístico classifica o documento em quatro níveis (*Low, Medium, High, Critical*) com base em uma combinação ponderada de indicadores: presença de /JS, /Launch, /OpenAction, objetos órfãos, avisos do parser QPDF e regras YARA acionadas. A *Orphaned Object Detection* mapeia todos os objetos fisicamente presentes no fluxo binário e os confronta com a tabela XRef; quaisquer objetos não catalogados são marcados como órfãos, padrão clássico de adulteração [10]. O *JavaScript Extractor* localiza, deofusca e embeleza automaticamente o código embutido, recurso essencial dada a prevalência de droppers ocultos em campos de formulário [2,7].

O painel Incremental *Updates / Gaps* visualiza, segmento a segmento, todas as atualizações incrementais aplicadas após a versão inicial do PDF, permitindo ao perito distinguir a versão originalmente assinada das modificações posteriores — pré-requisito para identificar *Shadow Attacks* descritos por Mainka et al. [4] e por Mladenov et al. [5]. A *Action Inspection* enumera todas as ações automáticas e o painel QPDF Warnings concentra os avisos sintáticos da *engine* subjacente [12], frequentemente correlacionados com tentativas de *exploit* de *parsers*.

O YARA Rules Manager permite carregar conjuntos de regras *.yar* e o *Malware Scan* aplica-as não apenas ao arquivo bruto, mas também aos *buffers* já decodificados pelo QPDF — fundamental para transpor camadas de ofuscação [11].

4.5. Extração de artefatos e indicadores de comprometimento

O *IOC Extractor* aplica expressões regulares sobre todo o conteúdo decodificado para coletar URIs (http/s), endereços IPv4 e endereços de e-mail, organizando-os em lista exportável. O *Embedded Files Extractor* identifica anexos ocultos em /Names e em fluxos /EmbeddedFiles e permite o dump para disco. O Links / *URIs Inventory* cataloga todas as anotações /Link que disparam endereços externos — vetor primário de *phishing* documental. O *AcroForm Inspector* detalha campos interativos (texto, *checkboxes*, listas) e o *Annotations Reader* lista comentários, realces e stamps que frequentemente preservam histórico de revisões internas. O *Keyword Scanner* faz varredura otimizada por strings sensíveis (eval, powershell.exe, /JavaScript, /Launch).

4.6. Recursos multimídia e tipografia

A *Image Gallery* processa todos os /XObject / Image, convertendo *colorspaces* nativos e aplicando os filtros declarados, com exportação em formato comum. Sobre as imagens extraídas opera o módulo de esteganografia, que fatia bit-planes do *Least Significant Bit* (LSB), técnica de detecção visual amplamente estudada na literatura forense [13]. Os módulos *Fonts* e *Font Table Inspector* mapeiam fontes embutidas (Type1, TrueType, CFF) e desempacotam tabelas de glifos (glyf, loca) — superfícies historicamente associadas a vulnerabilidades severas de *parsers* de fontes em sistemas operacionais e leitores de PDF.

4.7. Assinaturas digitais (PKCS#7/PAdES)

O *Digital Signatures Panel* concentra a análise de autenticidade. Ele desempacota o *payload* PKCS#7, decodifica a árvore ASN.1, e exibe a cadeia X.509 do assinante (*Subject*) e do emissor (*Issuer*), checando validades. A visualização gráfica do array /ByteRange evidencia quais porções do arquivo estão sob cobertura criptográfica e expõe imediatamente as áreas anexadas fora da cobertura — janela de oportunidade dos *Shadow Attacks* [4]. A *Cryptographic Assessment* classifica a força dos algoritmos empregados (alertando contra MD5, SHA-1 ou RSA-1024 [5]) e processa as estruturas DSS/LTV para *Long Term Validation*, incluindo dados de revogação (CRL/OCSP).

4.8. Visualização estatística e relatórios

Além do *heatmap* de entropia, o *Text DNA Visualizer* colore bytes por classe (alfanuméricos, controle, high-bit), facilitando o reconhecimento visual de *shellcodes* imersos no fluxo. O *File Layout Map* mostra a distribuição física dos objetos, o *Resource Treemap* informa quais recursos (imagens, fontes, texto) consomem maior espaço, e o *Page Geometry* inspeciona definições físicas (*MediaBox, CropBox, BleedBox*) para identificar conteúdos ocultos fora das margens visíveis. Os painéis *Statistics Dashboard* e *Compression Analysis* consolidam contadores quantitativos e taxas de compactação por filtro.

O *Report Generator* compila um documento de saída em *Markdown* ou HTML reunindo nível de risco, *hashes*, regras YARA acionadas, IOCs, metadados e linha do tempo, alinhando-se ao processo de Documentação contínua descrito em [1] e viabilizando integração imediata ao laudo pericial.

4.9. Ferramentas auxiliares e extensibilidade

O *Helpful Tools Belt* reúne utilitários técnicos comumente requisitados (conversor de bases, tabela ASCII, calculadora binária/hexadecimal, byte *swapper*, visualizador IEEE-754, *splitter/merger/shred* de arquivos, testador de regex, cliente HTTP/TCP, *demangler* C++). O Compare / Diff (Ctrl+D) realiza *diffing* binário entre o arquivo aberto e uma referência, marcando blocos adicionados ou removidos — operação típica de comparação entre versões alegadamente íntegras. A *Advanced Search* (Ctrl+F) cobre simultaneamente hex, *strings* ASCII e expressões regulares, no fluxo bruto e nos streams decodificados.

O sistema *Locard Plugin Manager*, exposto via LocardSDK.h, permite o carregamento dinâmico de bibliotecas externas que adicionam novas *views*, novos analisadores ou novos *decoders* sem recompilação do núcleo. Esse mecanismo possibilita a incorporação progressiva de detectores baseados em aprendizado de máquina [8] e *parsers* dedicados a ameaças emergentes, alinhando-se ao modelo de "centro de conhecimento" defendido por Cunha et al. [1].

5. DISCUSSÃO

Em relação a utilitários consagrados como pdfid e pdf-parser [3], o LOCARD PDF não substitui o paradigma de inspeção atômica, mas o complementa em uma única interface gráfica auditável. Em relação a abordagens baseadas em aprendizado de máquina [7,8], o foco do submódulo permanece na explicabilidade: cada achado é rastreável até o objeto, offset e regra que o produziu, atendendo aos requisitos probatórios de processos judiciais brasileiros. Em relação a suítes comerciais, o caráter aberto e a integração ao framework LOCARD permitem que polícias científicas e laboratórios universitários adaptem e estendam a ferramenta sem barreiras de licenciamento.

A combinação de heurística, regras YARA aplicadas a streams decodificados [11], análise de entropia [6] e validação criptográfica PAdES com visualização gráfica do /ByteRange [4,5] oferece, em conjunto, um espectro de cobertura que individualmente nenhum dos utilitários *open source* mencionados oferece de forma integrada. O modelo de *plugins* mantém a extensibilidade aberta a contribuições futuras, em consonância com o princípio digital de Locard [9] de que toda interação maliciosa com um documento eletrônico deixa traços passíveis de detecção.

6. CONCLUSÕES

Este trabalho apresentou o LOCARD PDF, submódulo integrado ao *framework* forense audiovisual LOCARD, dedicado à análise forense aprofundada de documentos no padrão PDF. A ferramenta combina, em ambiente único e auditável, mais de cinquenta funcionalidades distribuídas entre navegação estrutural, análise de baixo nível, heurística, *threat hunting* com YARA, extração automatizada de IOCs, validação criptográfica PKCS#7/PAdES, esteganografia visual, comparação binária e geração de relatórios. A arquitetura modular em C++, baseada em QPDF, Poppler, YARA, OpenSSL e Dear ImGui, e sustentada por uma abstração IDataSource que suporta disco, memória e rede, oferece à perícia uma bancada uniforme para triagem, análise, avaliação e documentação, conforme o fluxo proposto em [1]. Como trabalhos futuros, vislumbra-se a integração de modelos locais de aprendizado de máquina para classificação autônoma de PDFs maliciosos, a automação de consultas ativas a serviços de revogação (OCSP/CRL) durante a verificação LTV e o desenvolvimento de detectores especializados em manipulações em assinaturas manuscritas escaneadas presentes em laudos eletrônicos.

AGRADECIMENTOS

Os autores agradecem ao Sindicato dos Peritos Oficiais de Natureza Criminal do Estado do Ceará pelo apoio que tornou possível a participação neste congresso e consequente publicação deste trabalho.

REFERÊNCIAS BIBLIOGRÁFICAS

[1] D.O. Cunha; E.A. Silva; J.A. Lambert; R.O. Ribeiro. Peritus Framework: towards multimedia evidence analysis uniformization in brazilian distributed forensic model. Forensic Sci. Int.: Digit. Investig. 35: 301089 (2020).

[2] R. Stevens. Malicious PDF documents explained. IEEE Secur. Priv. 9: 80-82 (2011).

[3] D. Stevens. PDF Tools: pdfid and pdf-parser. Didier Stevens Labs (2019). Acessado em 24/05/2026, em https://blog.didierstevens.com/programs/pdf-tools.

[4] C. Mainka; V. Mladenov; S. Rohlmann. Shadow Attacks: hiding and replacing content in signed PDFs. Proc. Network and Distributed System Security Symposium (NDSS). 1-18 (2021).

[5] V. Mladenov; C. Mainka; K. Meyer zu Selhausen; M. Grothe; J. Schwenk. 1 Trillion dollar refund: how to spoof PDF signatures. Proc. ACM SIGSAC Conference on Computer and Communications Security (CCS). 1-14 (2019).

[6] R. Lyda; J. Hamrock. Using entropy analysis to find encrypted and packed malware. IEEE Secur. Priv. 5: 40-45 (2007).

[7] P. Laskov; N. Šrndić. Static detection of malicious JavaScript-bearing PDF documents. Anais do 27th Annual Computer Security Applications Conference (ACSAC). 373-382 (2011).

[8] D. Maiorca; B. Biggio; G. Giacinto. Towards adversarial malware detection: lessons learned from PDF-based attacks. ACM Comput. Surv. 52: 1-36 (2019).

[9] E. Casey. Digital Evidence and Computer Crime: Forensic Science, Computers and the Internet, Academic Press, Estados Unidos (2011) 1-840.

[10] ISO. ISO 32000-2: Document management — Portable document format — Part 2: PDF 2.0, International Organization for Standardization, Suíça (2020).

[11] V.M. Álvarez. YARA: the pattern matching swiss knife for malware researchers. VirusTotal Project (2024). Acessado em 24/05/2026, em https://virustotal.github.io/yara.

[12] J. Berkenbilt. QPDF: a content-preserving PDF document transformer. Open Source Project (2024). Acessado em 24/05/2026, em https://qpdf.sourceforge.io.

[13] M. Pelosi; C. Easttom. Identification of LSB image steganography using cover image comparisons. J. Digit. Forensics, Secur. Law 15: 1-19 (2020)